

SOC 2 (SERVICE ORGANIZATION CONTROL 2)

Trust Services Criteria - Sample Extract for Testing

INTRODUCTION TO SOC 2

SOC 2 is an auditing procedure that ensures service providers securely manage data to protect the interests of the organization and the privacy of its clients. SOC 2 compliance is based on the AICPA's (American Institute of Certified Public Accountants) five Trust Services Criteria.

The Five Trust Services Criteria:

1. Security - Protection against unauthorized access
2. Availability - System is available for operation and use as committed
3. Processing Integrity - System processing is complete, valid, accurate, timely, and authorized
4. Confidentiality - Information designated as confidential is protected
5. Privacy - Personal information is collected, used, retained, disclosed, and disposed of properly

CATEGORY 1: SECURITY

CC1.1 - Control Environment

The entity demonstrates a commitment to integrity and ethical values.

Criteria:

- Sets the tone at the top
- Establishes standards of conduct
- Evaluates adherence to standards of conduct
- Addresses deviations in a timely manner

Points of Focus:

- Board of directors demonstrates independence and exercises oversight
- Management establishes structures, reporting lines, and authorities
- Entity demonstrates commitment to attract, develop, and retain competent individuals
- Entity holds individuals accountable for internal control responsibilities

CC1.2 - Communication and Information

The entity internally communicates information, including objectives and responsibilities for internal control.

Criteria:

- Obtains or generates relevant, quality information
- Internally communicates information including objectives and responsibilities
- Communicates with external parties regarding matters affecting internal control

CC1.3 - Risk Assessment

The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

Criteria:

- Specifies suitable objectives
- Identifies and analyzes risk
- Assesses fraud risk
- Identifies and analyzes significant change

CC1.4 - Monitoring Activities

The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.

Criteria:

- Conducts ongoing and/or separate evaluations
- Evaluates and communicates deficiencies

CC2.1 - Logical and Physical Access Controls

The entity restricts logical and physical access to system resources, data, and software to authorized and appropriate users.

Criteria:

- Identifies and authenticates users
- Considers network segmentation
- Manages points of access
- Restricts access to information assets
- Removes access when appropriate
- Protects confidential information in transit and at rest
- Implements boundary protection systems

- Prevents unauthorized access to system resources

Points of Focus:

- Entity uses encryption to protect data in transit
- Entity uses encryption to protect data at rest
- Multi-factor authentication is required for remote access
- Access is restricted based on the principle of least privilege
- Physical access to data centers is restricted and monitored
- Biometric or badge-based access controls are in place

CC2.2 - System Operations

The entity monitors system components and the operation of those components for anomalies that could indicate security events.

Criteria:

- Implements detection policies and procedures
- Designs detection measures
- Implements filters to analyze anomalies
- Monitors infrastructure and software
- Defines incident response procedures

Points of Focus:

- Security Information and Event Management (SIEM) tools deployed
- Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) implemented
- Log aggregation and analysis performed regularly
- Automated alerts configured for suspicious activities
- Baseline behavior established for anomaly detection

CC2.3 - Change Management

The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures.

Criteria:

- Manages changes throughout the system lifecycle
- Authorizes changes prior to implementation
- Tests changes before deployment
- Documents changes

- Implements emergency changes according to defined procedures

Points of Focus:

- Change advisory board reviews significant changes
- Version control systems track all code changes
- Separate development, testing, and production environments maintained
- Rollback procedures documented and tested
- Change tickets include business justification and risk assessment

CC3.1 - Risk Mitigation

The entity identifies, selects, and develops risk mitigation activities arising from potential business disruptions.

Criteria:

- Determines dependency on external resources
- Establishes resilience requirements
- Identifies and assesses risks
- Selects risk mitigation activities

Points of Focus:

- Business Impact Analysis (BIA) conducted regularly
- Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) defined
- Critical business functions identified and prioritized
- Single points of failure identified and addressed
- Third-party dependencies assessed

CC3.2 - Continuity Planning and Testing

The entity designs, develops, implements, and tests business continuity plans.

Criteria:

- Establishes continuity objectives
- Designs and develops continuity plans
- Implements business continuity plan elements
- Tests, maintains, and revises continuity plans

Points of Focus:

- Disaster Recovery Plan (DRP) documented and maintained
- Business Continuity Plan (BCP) tested at least annually
- Backup systems and data verified regularly
- Alternative processing sites identified and tested
- Communication plans established for stakeholders

CC3.3 - Information Backup and Recovery

The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure.

Criteria:

- Implements environmental protection mechanisms
- Maintains data backup and recovery capabilities
- Tests data restoration procedures

Points of Focus:

- Automated backups performed daily
- Backups stored in geographically separate locations
- Backup encryption implemented
- Restoration procedures tested quarterly
- Backup monitoring and alerting configured

=====

CATEGORY 2: AVAILABILITY

=====

A1.1 - Availability

The entity maintains, monitors, and evaluates current processing capacity and use of system components to manage capacity demand and to enable the implementation of additional capacity.

Criteria:

- Measures current usage
- Forecasts capacity requirements
- Makes changes based on forecasted requirements
- Performs capacity management activities

Points of Focus:

- System performance metrics collected and analyzed
- Capacity planning reviews conducted quarterly
- Scalability testing performed
- Load balancing implemented
- Auto-scaling capabilities configured

A1.2 - System Availability Commitments

The entity achieves its availability commitments.

Criteria:

- Defines system availability commitments
- Measures actual system availability
- Reports on system availability
- Takes corrective action when commitments are not met

Points of Focus:

- Service Level Agreements (SLAs) defined and documented
- Uptime requirements specified (e.g., 99.9%, 99.99%)
- Planned maintenance windows communicated in advance
- Availability metrics tracked and reported monthly
- Root cause analysis performed for outages

A1.3 - Environmental Safeguards

The entity implements environmental safeguards to protect system components from environmental factors.

Criteria:

- Implements controls to protect against environmental threats
- Monitors environmental controls
- Maintains environmental protections

Points of Focus:

- Redundant power supplies and UPS systems deployed
- HVAC systems maintain optimal temperature and humidity
- Fire suppression systems installed and tested
- Water leak detection systems implemented

- Environmental monitoring alerts configured

=====

CATEGORY 3: PROCESSING INTEGRITY

=====

PI1.1 - Processing Completeness and Accuracy

The entity implements policies and procedures to ensure system processing is complete, accurate, timely, and authorized.

Criteria:

- Designs processing procedures for completeness and accuracy
- Implements input controls
- Implements processing controls
- Implements output controls
- Implements error correction procedures

Points of Focus:

- Input validation rules implemented
- Data type and format checks performed
- Duplicate detection mechanisms in place
- Referential integrity constraints enforced
- Transaction logs maintained for audit trail

PI1.2 - Processing Quality

The entity implements quality control procedures to achieve processing objectives.

Criteria:

- Reviews system inputs and outputs
- Creates and maintains processing documentation
- Monitors processing quality

Points of Focus:

- Automated quality checks implemented
- Exception reports generated and reviewed
- Data reconciliation performed regularly

- System output validated against expected results
- Quality metrics tracked and reported

PI1.3 - Processing Authorization

The entity requires appropriate authorization for system processing activities.

Criteria:

- Restricts access to processing activities
- Implements authorization controls
- Reviews and approves system changes

Points of Focus:

- Role-based access control (RBAC) implemented
- Segregation of duties enforced
- Approval workflows defined for critical transactions
- Authorization matrices documented
- Privileged access monitored and logged

PI1.4 - Completeness of Processing

The entity achieves its objectives related to the completeness of processing.

Criteria:

- Monitors processing completeness
- Retains data for the defined period
- Implements controls to ensure processing occurs as scheduled

Points of Focus:

- Job scheduling and monitoring tools deployed
- Failed job alerts configured
- Batch processing logs reviewed
- Data retention policies defined and enforced
- Archive and retrieval procedures documented

PI1.5 - Accuracy of Processing

The entity achieves its objectives related to the accuracy of processing.

Criteria:

- Reviews system inputs for accuracy
- Performs calculations and processing accurately
- Validates output accuracy

Points of Focus:

- Calculation logic tested and validated
- Rounding and truncation rules documented
- Data transformation rules verified
- Output validation checks implemented
- Reconciliation processes established

=====
CATEGORY 4: CONFIDENTIALITY
=====

C1.1 - Confidential Information

The entity identifies and maintains confidential information to meet its objectives related to confidentiality.

Criteria:

- Identifies confidential information
- Implements procedures to protect confidentiality
- Implements controls over disposal of confidential information

Points of Focus:

- Data classification policy established
- Confidential data labeled and tagged
- Encryption standards defined and implemented
- Secure disposal procedures for media and documents
- Non-disclosure agreements (NDAs) signed by personnel

C1.2 - Confidential Information Protection

The entity restricts access to confidential information.

Criteria:

- Limits access to authorized personnel
- Protects confidential information during transmission
- Protects confidential information at rest
- Restricts physical access to confidential information

Points of Focus:

- Need-to-know basis enforced
- TLS/SSL encryption for data in transit
- AES-256 encryption for data at rest
- Tokenization or masking used where appropriate
- Clean desk policy enforced

=====

CATEGORY 5: PRIVACY

=====

P1.1 - Privacy Notice

The entity provides notice to data subjects about its privacy practices.

Criteria:

- Identifies purposes for collection and use
- Describes types of personal information collected
- Describes choices available
- Describes rights of data subjects
- Updates privacy notice when practices change

Points of Focus:

- Privacy policy published and accessible
- Cookie consent banners implemented
- Privacy notice provided at point of collection
- Language is clear and understandable
- Effective date clearly stated

P2.1 - Choice and Consent

The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information.

Criteria:

- Informs data subjects of choices
- Obtains explicit consent when required
- Obtains opt-in consent for sensitive information
- Allows data subjects to update preferences

Points of Focus:

- Consent management platform implemented
- Granular consent options provided
- Consent withdrawal mechanisms available
- Consent records maintained
- Parental consent obtained when required

P3.1 - Collection of Personal Information

The entity collects personal information only for the purposes identified in the privacy notice.

Criteria:

- Limits collection to stated purposes
- Collects from authorized sources
- Implements data minimization practices

Points of Focus:

- Data collection forms reviewed for necessity
- Purpose limitation enforced
- Third-party data sharing agreements reviewed
- Data inventory maintained
- Collection methods documented

P4.1 - Use, Retention, and Disposal

The entity uses personal information only for the purposes identified in the privacy notice and retains it for the time necessary to fulfill those purposes.

Criteria:

- Uses personal information consistently with privacy notice

- Retains personal information for defined period
- Disposes of personal information securely
- De-identifies personal information when retention is no longer necessary

Points of Focus:

- Data retention schedule established
- Automated deletion processes implemented
- Secure deletion methods used (e.g., cryptographic erasure)
- Personal information purged after retention period
- Audit logs of deletion activities maintained

P5.1 - Access to Personal Information

The entity grants data subjects access to their personal information for review and update.

Criteria:

- Provides data subjects access to their information
- Allows data subjects to update or correct information
- Authenticates identity before granting access

Points of Focus:

- Self-service portals for data access implemented
- Request fulfillment within 30 days
- Identity verification procedures established
- Accessible format provided
- Partial access restrictions documented

P6.1 - Disclosure and Notification

The entity discloses personal information to third parties with the consent of data subjects and provides notification when required.

Criteria:

- Obtains consent before disclosure
- Discloses only as described in privacy notice
- Notifies data subjects of breaches
- Enters into agreements with third parties

Points of Focus:

- Vendor due diligence performed
- Data Processing Agreements (DPAs) signed
- Breach notification procedures defined
- Notification timelines comply with regulations
- Subprocessor list maintained and disclosed

P7.1 - Quality of Personal Information

The entity maintains accurate and complete personal information.

Criteria:

- Obtains accurate information
- Implements controls to maintain accuracy
- Allows data subjects to correct information

Points of Focus:

- Data quality rules implemented
- Periodic data accuracy reviews conducted
- Correction workflows established
- Data validation at point of entry
- Third-party data verified for accuracy

P8.1 - Privacy Complaint Management

The entity addresses privacy complaints and disputes.

Criteria:

- Documents complaint procedures
- Investigates complaints
- Resolves complaints in timely manner
- Communicates resolution to complainants

Points of Focus:

- Privacy complaint form available
- Complaints logged and tracked
- Investigation completed within 45 days

- Escalation procedures defined
- Regulatory notifications made when required

=====

SECURITY INCIDENT RESPONSE

=====

Incident Response Plan Requirements:

1. Incident identification and reporting procedures
2. Incident classification and prioritization
3. Containment, eradication, and recovery procedures
4. Post-incident review and lessons learned
5. Communication protocols for stakeholders

Incident Response Phases:

1. Preparation - Establish incident response team and procedures
2. Detection and Analysis - Identify and assess security incidents
3. Containment - Limit the scope and magnitude of the incident
4. Eradication - Remove the threat from the environment
5. Recovery - Restore systems to normal operations
6. Post-Incident Activity - Document lessons learned and improve procedures

=====

VENDOR AND THIRD-PARTY MANAGEMENT

=====

Vendor Management Requirements:

1. Conduct due diligence before engaging vendors
2. Assess vendor security controls
3. Review SOC 2 reports or equivalent certifications
4. Include security requirements in contracts
5. Monitor vendor performance
6. Conduct periodic vendor risk assessments
7. Maintain vendor inventory
8. Implement offboarding procedures

Critical Vendor Considerations:

- Data residency requirements
- Subprocessor management
- Right to audit clauses
- Data breach notification requirements
- Data return and deletion upon termination
- Insurance requirements
- Compliance with applicable regulations

=====

COMPLIANCE MONITORING AND REPORTING

=====

Ongoing Monitoring Activities:

1. Quarterly security control testing
2. Monthly vulnerability scanning
3. Annual penetration testing
4. Continuous compliance monitoring
5. Regular policy and procedure reviews
6. Training and awareness programs
7. Management reviews of security metrics

Reporting Requirements:

1. Board of Directors - Quarterly security briefings
2. Executive Management - Monthly security dashboards
3. Audit Committee - Semiannual compliance reports
4. Regulators - As required by applicable laws
5. Customers - Annual SOC 2 report distribution
6. Incident Reports - Within defined timeframes

=====

END OF SAMPLE EXTRACT

=====